INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY

GRC105 Incident Management and Business Continuity

Incident Response Planning Assignment

Northbridge Skills Institute: suspected ransomware incident

Submission detail	Entry
Student name	OUABO KAMDEM DERRICK ARNAUD
Student ID	2025/GCR/12778
Official email	gcr2512778@students.icdfa.edu.ng
Programme	CGRCE
Word count	Approximately 8,221 words (framework section through Appendix A, including tables; excluding this cover page, the reference list and the AI acknowledgement)
Citation style	APA 7th edition; the teaching deck is cited by slide number
Date of submission	20/10/2026

All data in this report is fictional. Assumptions are labelled and listed in Appendix A.

Framework, conventions and approach

This report is organised using the four ICDFA teaching stages: preparation; detection and analysis; containment, eradication and recovery; and post-incident activity (ICDFA, 2026, slides 6–13). Where NIST SP 800-61 Revision 3 is cited, its CSF 2.0 alignment is used: Detect, Respond and Recover form incident response, while Govern, Identify and Protect support preparation, and continuous improvement feeds lessons into all functions (NIST, 2025). The four-stage model is the ICDFA teaching model and is not attributed to Revision 3.

Teaching stage	CSF 2.0 alignment	Where addressed
Preparation	Govern, Identify, Protect	Task 2 (policy, CSIRT, RACI, readiness checklist)
Detection and analysis	Detect (with analysis inside Respond)	Task 1; playbook actions 1–8 in Task 3
Containment, eradication and recovery	Respond, Recover	Task 3 and Task 4
Post-incident activity	Improvement feeding all functions	Task 5 and Task 6

Conventions. All times are West Africa Time (WAT). Day 0 is Monday; I take control at 08:45. Evidence IDs E01–E08 come from the supplied pack. Every added assumption is labelled “Assumption” and listed in Appendix A. All names, numbers and contact details are fictional. Evidence collection is shown as planned or not yet collected; no hashes, acquisitions or results are claimed.

Task 1 Incident classification and initial assessment

1.1 Evidence-linked timeline

"Confirmed" means directly observed or reported in the evidence pack. Hypotheses are my working explanations and are not established fact. No attacker identity and no theft of personal data is asserted.

Table 1. Incident timeline with uncertainty

Time (WAT)	ID	Confirmed observation	Working hypothesis	Unresolved question
Day −3 (Fri) 17:00	Scenario	Last disconnected backup was taken.	Predates E01–E08, so it is the best candidate recovery point.	Is it complete and readable? No restore test in 90 days.
Day −1 16:40	E01	Finance officer opened an unexpected payroll attachment on FIN-PC07 (user report, mail record).	The attachment delivered malware (phishing).	Did the code run? What was the attachment?
Day 0 01:15	E02	Finance officer M365 account signed in from an unfamiliar IP and new device.	Credentials or session stolen after E01 and reused by an attacker.	Was MFA satisfied? Was it the user?
Day 0 01:35	E03	svc_backup made remote administrator logons to FS01 and BAK01 outside its schedule.	svc_backup credentials were harvested and used for lateral movement and to reach backups.	Why did it log on? From which source host?
Day 0 01:50	E04	FIN-PC07 uploaded 1.2 GB over HTTPS to unfamiliar cloud storage.	Data staged and exfiltrated before encryption.	What was in the upload? Who owns the destination?
Day 0 02:00	E05	Backup console reports success for FS01 and LMS01 jobs.	Jobs ran on already compromised data, or the reports are unreliable.	Are the backups recoverable and clean?
Day 0 08:30	E06	EDR and helpdesk: mass file changes on FIN-PC07; FS01 shares hold .locked files and a ransom note.	Ransomware is executing on FIN-PC07 and FS01.	Malware family? Full encryption scope? Is it still spreading?
Day 0 08:40	E07	Portal login page loads; learners cannot open materials or submit assessments.	LMS01 depends on files on FS01, so FS01 encryption breaks the portal.	Is LMS01 itself damaged or compromised?
Day 0 08:45	E08	Incident contact list on FS01 is inaccessible; staff phones work; email trust is unverified.	A direct effect of FS01 encryption; attacker may be reading email.	Is the finance officer mailbox or any other mailbox accessed?
Day 0 11:00	Scenario	Online exam for 100 learners is scheduled (135 minutes after I take control).	—	Can a safe service be provided by then?

Alternative explanations for ambiguous events

Table 2. Alternatives and how to tell them apart

Event	Adversary hypothesis	Plausible alternative explanations	Evidence that would distinguish them
E02 unfamiliar sign-in	Attacker used stolen credentials or a stolen session token.	(a) The officer signed in legitimately from a new phone or home network. (b) A colleague or IT staff member used the account for a task.	M365 sign-in detail (IP, device ID, MFA method, token type); officer interview; device compliance record.
E03 svc_backup logons	Attacker used harvested service credentials.	(a) Authorised weekend maintenance or a backup job re-run. (b) A scheduler change shifted the job time.	Change calendar; logon type and source host in Windows Security logs; backup administrator interview.
E04 1.2 GB upload	Data exfiltration.	(a) Approved cloud sync or payroll upload to a vendor. (b) Personal sync app copying user files.	Destination domain ownership and reputation; full proxy record; EDR file-read telemetry on FIN-PC07.
E05 backup success	Backups are usable.	(a) Jobs succeeded but captured encrypted or tampered data. (b) Success status hides empty or corrupt sets.	Sandbox restore of a sample; BAK01 audit log for deletions or retention changes.
E07 portal failure	FS01 dependency.	(a) LMS01 independently infected. (b) Unrelated application or database fault.	LMS01 event and application logs; file-path dependency check; read-only integrity check.

1.2 Classification and severity

Incident type. Suspected ransomware with probable account compromise and possible data breach. Ransomware and data breaches are both Critical categories in the teaching deck (ICDFA, 2026, slide 4).

Table 3. Severity criteria and response

Level	Criteria	Response (see slide 10)
Critical	Active or confirmed malicious compromise AND at least one of: loss of a core service; possible exposure of personal or sensitive data; recovery path (backups) at risk; time-critical business event at risk.	Immediate full CSIRT activation; executive notification required; hourly updates.
High	Confirmed malicious activity with significant but bounded impact on a non-core system; no indication of data exposure; recovery path intact.	Core team response within 1 hour (Assumption A2); management notified.
Medium	Suspicious or single-endpoint malware activity with limited impact and no service disruption.	Same-day handling; ticketed and tracked.
Low	Policy violation, blocked attempt or false positive with no impact.	Standard workflow; documented in the ticketing system.

Selected severity: Critical (provisional, reviewed hourly).

- **Operational impact.** FS01 shares and the finance workstation are encrypted (E06). Learners cannot open materials or submit work (E07). The incident contact list is unreachable (E08). The exam for 100 learners starts in 135 minutes.

- **Affected data.** The institute holds learner contact details, admission documents, assessment records and finance files. The 1.2 GB upload (E04) and the ransom note (E06) make exposure plausible but unproven.
- **Uncertainty.** The backup route may be compromised (E03, E05), non-immutable and untested. Because the worst credible case is severe and cannot yet be disproved, I classify on that case until evidence lowers it.

1.3 Affected assets and impact on confidentiality, integrity and availability

Table 4. Asset status

Status	Assets	Basis
Confirmed affected	FIN-PC07; FS01 shared folders; incident contact list (stored on FS01)	E01, E04, E06, E08
Confirmed degraded, cause unresolved	LMS01 (materials and submission unavailable; login page loads)	E07
Potentially affected	Finance officer M365 account and mailbox; svc_backup; BAK01; FS01 and LMS01 backup sets; other workstations and servers (server EDR coverage incomplete); learner, admission, assessment and finance data	E02, E03, E04, E05
No evidence of impact yet	Other M365 identities and mailboxes; learner devices	Not yet investigated

Table 5. CIA assessment

Property	Assessment	Confidence and basis
Confidentiality	Potentially high impact. Possible exfiltration of finance and learner data and a possible extortion claim.	Unconfirmed. E04 shows a transfer, not its content. E06 note does not prove theft.
Integrity	High impact on FS01 and FIN-PC07 files. Possible tampering with backups and LMS01 data.	Confirmed for encrypted files (E06). Potential for backups (E03, E05) and LMS01 (E07).
Availability	High impact. Shared files, learning materials, submissions and the contact list are unavailable. Exam at risk.	Confirmed (E06, E07, E08).

1.4 Response priorities

Table 6. Priorities

#	Priority	Reason	Target
1	Stop spread and protect recovery data: isolate FIN-PC07 and FS01; disable svc_backup; cut off BAK01.	Encryption is active (E06) and svc_backup reached BAK01 (E03). A destroyed backup removes the safe recovery path.	By 09:10
2	Take control: activate the CSIRT by phone and open an out-of-band channel.	Contact list is lost and email is untrusted (E08).	By 09:00
3	Preserve volatile evidence before rebuilding.	Memory and logs are lost on reboot; needed for scope and any notification decision.	By 09:35

#	Priority	Reason	Target
4	Contain identity: finance officer account and sessions.	E02 suggests possible account takeover.	By 09:20
5	Decide the 11:00 exam by a fixed gate, without restoring from an unverified backup.	Deadline pressure must not override backup safety (E05).	Decision by 09:45
6	Scope possible data exposure (E04) and brief legal or privacy advice.	Determines whether a formal breach process is needed.	Start by 09:45

1.5 Investigation priorities

Table 7. Priority investigation questions

Question	Resolving log, artefact, interview or check	Finding that would change severity or scope
Q1. What was in the 1.2 GB upload (E04) and who owns the destination?	Full proxy and firewall records; EDR file-access telemetry for FIN-PC07; memory and disk triage (planned); domain ownership lookup.	Learner or finance records confirmed: severity stays Critical and a formal breach assessment starts. Benign sync confirmed: confidentiality concern drops, severity stays Critical on integrity and availability.
Q2. Was svc_backup misused, and is BAK01 or any backup compromised (E03, E05)?	Windows Security logon events (type, source host) on FS01 and BAK01; backup audit and retention logs; interview with the backup administrator; sandbox test restore.	Attacker use confirmed: scope widens to every system svc_backup can reach and no network backup is trusted. Authorised change confirmed: backup suspicion falls.
Q3. Was the finance officer account taken over (E02)?	M365 sign-in and audit logs (IP, device, MFA method); mailbox rules, forwarding and app consents; interview with the officer.	Takeover confirmed: scope includes the tenant and mail, email stays untrusted and a business email compromise check starts. Legitimate sign-in: scope narrows to endpoints.
Q4. Is LMS01 compromised or only dependent on FS01 (E07)?	LMS01 event and application logs; read-only file integrity check; dependency map of file paths.	LMS01 encrypted or modified: exam restoration needs a rebuild and the exam cannot run today. Dependency only: faster restoration once FS01 content is validated.

Task 2 Incident response plan and team responsibilities

2.1 Policy and plan outline

The outline follows the plan components in the teaching deck: mission and structure, roles and escalation, communication, and resources (ICDFA, 2026, slide 14). Governance elements support preparation under CSF 2.0 (NIST, 2025).

Table 8. Northbridge incident response policy and plan outline

Element	Content
Mission	Protect learners, staff and assessment integrity by detecting, containing and recovering from security incidents quickly, lawfully and with evidence preserved.
Objectives	(1) Classify within 30 minutes of first report. (2) Contain active threats within 30 minutes of declaration. (3) Preserve evidence to a forensic standard. (4) Restore only validated services approved by the business owner. (5) Communicate accurately to every stakeholder group. (6) Learn from every incident.
Scope	All Northbridge systems, data and staff, including FIN-PC07, FS01, LMS01, BAK01, Microsoft 365 identity and email, and third-party providers handling institute data.
Incident declaration	The Incident Manager (IM) declares an incident when evidence shows a probable breach of confidentiality, integrity or availability, or a policy violation with security impact. Severity follows Table 3. Any validated ransomware, probable personal data exposure, backup compromise, or threat to a time-critical event is Critical.
Activation and escalation	Critical: full CSIRT, executive notification at once. High: core team (IM, Security Analyst, IT Operations Lead) and management notified within 1 hour. Medium and Low: ticketed. Escalation triggers are in Table 17. Deputy IM is the IT Operations Lead.
Authority to isolate systems	The IM, or in the IM's absence the deputy or the Security Analyst, may isolate any system without prior approval when there is evidence of active compromise, spread or data loss. The Executive Sponsor must be informed within 15 minutes. Shutting down the Microsoft 365 tenant or a live examination requires Executive Sponsor approval.
Documentation	A time-stamped incident log (WAT) records detection time, indicators, affected systems, actions, decisions with owner and rationale, evidence collected, custody, notifications and costs (ICDFA, 2026, slides 10 and 13). The scribe records under the IM's direction.
Plan review	Annually; after every Critical or High incident; after each exercise; contact list verified monthly. Changes are approved by the Executive Sponsor.
Link to business continuity	Critical declaration also alerts the business owner, who decides continuity actions (postpone, relocate or run exams offline). Recovery time and data-loss targets come from the business impact analysis; until one exists, Appendix A (A8) sets working targets. After each incident, findings update the business impact analysis and recovery targets (ICDFA, 2026, slide 18).

2.2 CSIRT structure

Table 9. CSIRT roles

Role (code)	Responsibilities	Filled by
Incident Manager (IM)	Leads the response, declares and classifies, holds isolation authority, maintains the log, escalates to executives.	IR Lead (me)

Role (code)	Responsibilities	Filled by
Executive Sponsor (ES)	Approves external spend, exam and public decisions, risk acceptance and closure of actions.	Institute Director
Security Analyst (SA)	Triage, log analysis, threat hunting, identity containment, monitoring.	Security analyst
Forensics Lead (FL)	Evidence acquisition, integrity and custody, root cause analysis.	External forensic provider; SA acts until engaged (A3)
IT Operations Lead (ITO)	Isolation actions, credential rotation, rebuild and restore, backup validation.	Senior IT staff member (deputy IM)
Business Owner (BO)	Owns continuity decisions: exam status, acceptable data loss, approves return of service.	Head of Examinations
Legal and Privacy Adviser (LP)	Assesses notification duties, regulator and law-enforcement contact, wording review.	Data protection officer or external counsel
Communications Lead (CL)	Drafts and sends learner, staff and media messages; holds the message log.	Administration manager

A scribe from the IT team supports the IM. **Additional support for a small team (three IT staff and one analyst):** (1) an external incident response and forensic provider engaged by the Executive Sponsor (the deck lists external IR firms and ISACs as stakeholders, slide 15); (2) the Microsoft 365 and backup vendors' support lines; (3) a national CSIRT or sector information-sharing group for threat intelligence; (4) staff from administration, rostered to handle phones, logging and runner tasks; (5) rotation into 12-hour shifts so that the same four technical staff are not on duty beyond one shift without relief.

2.3 RACI matrix

R Responsible: does the work. **A** Accountable: answerable for the outcome and approves it; exactly one per activity. **C** Consulted: gives input before action. **I** Informed: told after action. **A/R** means one role is both. A dash means no role.

Table 10. RACI for the Northbridge CSIRT

Activity	IM	ES	SA	FL	ITO	BO	LP	CL
1 Detection and triage	A	I	R	I	C	–	–	–
2 Analysis and classification	A	I	R	C	C	C	I	I
3 Incident declaration and activation	A/R	I	C	I	I	I	I	I
4 Containment (isolation)	A	I	R	C	R	C	I	I
5 Evidence handling	I	–	R	A/R	C	–	C	–
6 Eradication and credential reset	C	I	R	C	A/R	I	–	–
7 Stakeholder communication	A	C	I	I	I	C	C	R
8 Assessment of reporting obligations	C	C	C	C	I	I	A/R	I
9 Restoration approval	R	I	R	C	R	A	I	I
10 Closure and review	R	A	R	C	C	C	C	C

Check: every row has exactly one A (rows 3, 5, 6 and 8 combine A with R) and at least one R. This matrix extends the five-activity example in the teaching deck (slide 15) with declaration, eradication, reporting obligations, restoration approval and closure, and adds executive, legal, communications and business roles.

2.4 Preparation improvements and readiness checklist

Preparation is continuous and cyclical (ICDFA, 2026, slides 7–8). Backups should be offline, encrypted and tested for availability and integrity (CISA & partners, 2023).

Table 11. Readiness checklist

#	Improvement	Owner	Resources	How readiness is checked
1	**Backup readiness.** Add an immutable or offline copy of FS01, LMS01 and BAK01 data; separate backup credentials; document restore runbooks.	ITO	Immutable storage or offline media rotation; 2 staff days per quarter for tests.	Quarterly restore test of FS01 and LMS01 into an isolated network, with measured time and a pass or fail record; report to ES.
2	**Accessible incident contact list.** Keep it outside FS01 and corporate email: printed sealed copy, encrypted offline copy, and numbers stored on CSIRT phones.	IM	Printing; encrypted USB; 1 staff day.	Monthly call test of every CSIRT member and deputy; 100% reached within 15 minutes.
3	**Tools.** Extend EDR to FS01, LMS01 and BAK01; forward server and M365 logs to central storage; use an incident ticketing tool.	SA	EDR server licences; log storage; 3 staff days.	Coverage report shows 100% of servers; a benign test detection raises an alert on each server class.
4	**Privileged accounts.** Remove administrator rights from svc_backup where possible, vault credentials, alert on off-schedule logons, enforce MFA and conditional access.	ITO	Identity admin time; alert rules.	Access review signed off; test off-schedule logon triggers an alert within 15 minutes.
5	**Secure communication.** Out-of-band messaging group, conference bridge and holding-statement templates for learners, staff and media.	CL	Messaging group; template pack approved by LP.	Used in every exercise; templates approved and dated; test message delivered to all CSIRT members.
6	**Training.** Phishing awareness for finance and all staff; role-specific CSIRT training; annual tabletop exercise.	SA	Training platform or workshop; 1 day per year per CSIRT member.	Completion at least 95%; phishing simulation click rate trending down; exercise held and actions tracked.
7	**External support.** Retainer with a forensic and incident response provider; counsel contact; cyber insurance hotline.	ES	Contract budget.	Signed engagement; out-of-hours call test each half year.

Task 3 Response playbook and evidence preservation

3.1 Playbook for the first 24 hours

Actions 1–7 cover the first 60 minutes after 08:45; actions 8–14 cover the remainder of the first 24 hours. Containment steps follow the CISA checklist logic: isolate affected systems, preserve volatile evidence and take images and memory captures of a sample of affected devices (CISA & partners, 2023). Owners are roles from Table 9. Planned evidence is not yet collected.

Table 12. Response playbook

Time or stage	Action	Owner	Required approval	Evidence to retain	Completion check
1 08:45–08:50 Short-term containment	Declare a Critical incident (E06, E07). Start the incident log. Call the core CSIRT by phone using staff phones (E08). Open an out-of-band bridge.	IM	ES informed by phone	Declaration time; call log; log entry	Six core roles acknowledge by phone
2 08:50–09:00 Short-term containment	Photograph the ransom note and screen state. Isolate FIN-PC07 (EDR isolation) and FS01 (switch port or cable; no EDR agent) while leaving both powered on. Do not reboot or wipe.	ITO; SA assists	IM (isolation authority)	Photos with time; EDR isolation record; switch-port change record	No traffic from either host in EDR and switch logs
3 09:00–09:10 Short-term containment	Export svc_backup logon records (E03). Disable svc_backup and end its sessions. Pause backup and retention jobs. Block network access to BAK01 except from a clean admin console.	ITO	IM	Logon export; backup job and retention settings; account change log	No active svc_backup sessions; BAK01 unreachable from server and user networks
4 09:10–09:20 Short-term containment	Export M365 sign-in and audit logs for the finance officer (E02). Then revoke sessions, reset the password, require supervised MFA re-registration, review mailbox rules, forwarding and app consents, and block the unfamiliar IP.	SA with ITO	IM	Log export EV-04; list of rules and consents found; change record	No active sessions; rules reviewed; MFA re-registered
5 09:15–09:25 Short-term containment	Block the unfamiliar cloud storage destination (E04) at proxy and firewall. Watch all hosts for similar uploads.	ITO	IM	Proxy and firewall logs EV-06; rule change record	Test request blocked; no further transfers for 30 minutes

Time or stage	Action	Owner	Required approval	Evidence to retain	Completion check
6 09:20–09:35 Investigation (evidence)	Preserve evidence in order of volatility: memory capture and triage image of FIN-PC07; FS01 event logs and ransom note; quarantined copy of the E01 attachment from message trace.	FL (SA acts until FL engaged)	IM	Items EV-01 to EV-07; tool versions; times	Register complete; hash recorded at collection (planned); custody entry for each item
7 09:35–09:45 Investigation and communication	Hold the first bridge. Send a holding message to staff by SMS or phone. Present exam options against criteria. Notify LP and request an external forensic provider.	IM with CL	ES (exam decision; external spend)	Bridge notes; decision record; staff message text	Exam decision recorded; staff informed; LP and provider contacted
8 09:45–11:00 Investigation	Check for broader compromise: fleet-wide EDR search for the ransom note name, .locked files, the E01 attachment and the E04 destination; other svc_backup logons; privileged group changes; new accounts; scheduled tasks; M365 app consents; read-only integrity check of LMS01; list hosts without EDR.	SA; FL	IM	Query exports; indicator list; list of unmonitored hosts	Hosts labelled confirmed, suspected or clear; gaps listed
9 11:00–13:00 Longer-term containment	Rotate all privileged, service and local administrator credentials. Enforce MFA and conditional access. Restrict SMB and RDP between workstations and servers. Segment BAK01. Apply emergency patches if an exploited weakness is found.	ITO	IM	Change tickets; rotation register (no secrets recorded); before and after settings	Each listed account rotated; test sign-ins; segmentation test passed
10 13:00–16:00 Eradication	Remove persistence (services, tasks, run keys, new accounts, mailbox rules, app consents). Rebuild FIN-PC07 from a known-good image rather than cleaning it. Purge the phishing email from all mailboxes; block sender and attachment type.	ITO; SA	IM; FL confirms evidence is acquired	Persistence artefact list; mail purge report; rebuild records	Two scanning engines and EDR show no indicators; rebuilt hosts patched with EDR
11 13:00–18:00 Recovery (parallel): backup selection	Validate candidate backups in an isolated sandbox: scan, compare timestamps with E01 and E03, attempt test restores. Prefer the Day −3 17:00 disconnected backup.	ITO; SA	BO accepts data loss; IM	Validation report; scan output; restore logs; media custody record	Candidate meets acceptance criteria 1 to 3 (Table 15)

Time or stage	Action	Owner	Required approval	Evidence to retain	Completion check
12 18:00–Day 1 02:00 Recovery: controlled restore	Rebuild FS01 and LMS01 clean with EDR. Restore exam-critical LMS01 and FS01 content into a quarantined network. Run integrity and function tests.	ITO	IM confirms criteria; BO approves next step	Restore logs; test results; checksum comparisons	Acceptance criteria 1 to 6 met
13 Day 1 02:00–06:00 Monitoring and phased return	Staff-only pilot with enhanced monitoring. Review alerts. Confirm rollback is ready.	SA; ITO	BO	Alert export; pilot record	No indicator alerts for at least 4 hours
14 Day 1 06:00–08:45 Closure of first 24 hours	BO go or no-go for an exam-only service. Send status reports. Schedule the post-incident review. Hand over the shift log.	IM	BO; ES	Approval record; handover log; review invitation	Decision logged; handover signed; review date set

3.2 Checking for broader compromise

Action 8 treats every system touched by FIN-PC07 users, svc_backup or the finance officer account as suspect until cleared. I will search by indicators from E01 to E06, review identity and privilege changes in M365, check for lateral movement protocols between hosts, and list hosts that lack EDR so they can be inspected manually. A host is “clear” only when logs and a clean scan agree. A coverage gap is recorded as unresolved risk and is not treated as clean.

3.3 Justification of two difficult decisions

Decision A: containment while preserving useful evidence

Immediate isolation is necessary here: files are being encrypted (E06) and svc_backup has already reached BAK01 (E03), so waiting risks wider encryption and loss of the backup route. I will isolate by network disconnection and keep machines powered on, because power-off or reboot loses volatile memory; CISA advises powering down only when disconnection is not possible (CISA & partners, 2023). The photographs and log exports in actions 2 to 4 come before any change that could alter state, and memory is captured once the host is isolated. If any evidence is lost (for example FS01 memory because it has no EDR), I will log what was lost, when, why, who approved the action and the effect on the investigation. I will also log operational impact, such as the portal and shared files staying down, as a deliberate and approved cost.

Decision B: restoring examination access while backup safety is uncertain

I will not reopen the portal or restore from the unverified network backup for the 11:00 exam. The network backups are not immutable and untested, svc_backup activity (E03) casts doubt on BAK01, and a “success” status (E05) proves nothing about recoverability. A rushed restore could re-expose learners to the attacker, overwrite evidence and destroy the only clean recovery point. The cost is a postponed exam for 100 learners. The Business Owner and Executive Sponsor will record this risk acceptance, and the earliest safe offer is an exam-only service built clean from a validated backup (Table 14), expected within 24 hours if validation passes. I will recommend postponement by the 09:45 gate and revisit the gate time in Task 6.

3.4 Evidence register

All items below are **planned and not yet collected**. Hashes, times and custody entries are completed at the moment of collection. Times are shown in WAT.

Table 13. Evidence register

ID	Source	Proposed collection	Collector role	Date and time (WAT)	Integrity check	Secure storage	Custody transfers
EV-01	FIN-PC07 memory	Memory capture from the isolated, powered-on host	FL (SA acts)	Day 0, to be recorded at collection	SHA-256 at acquisition (planned)	Encrypted evidence drive, locked cabinet	Collector → evidence custodian → external provider, signed each time
EV-02	FIN-PC07 disk	Forensic triage image, then full image	FL	Day 0, to be recorded	SHA-256 of image and source (planned)	Same as EV-01	Same as EV-01
EV-03	FS01 logs, ransom note, sample encrypted files	Export Windows event logs; copy note and samples read-only	FL; ITO assists	Day 0, to be recorded	SHA-256 per file (planned)	Same as EV-01	Same as EV-01
EV-04	M365 sign-in and audit logs (E02)	Export via admin audit and sign-in logs	SA	Day 0, to be recorded	SHA-256 of export (planned)	Restricted evidence share on a clean system	Collector → custodian
EV-05	Windows Security logs and backup console logs (E03, E05)	Export from FS01, BAK01 and the backup console	SA; FL	Day 0, to be recorded	SHA-256 (planned)	Same as EV-01	Collector → custodian
EV-06	Proxy and firewall records (E04)	Export full records for FIN-PC07 for the period	ITO	Day 0, to be recorded	SHA-256 (planned)	Restricted evidence share	Collector → custodian
EV-07	Phishing email and attachment (E01)	Message trace export; quarantined copy of attachment	SA	Day 0, to be recorded	SHA-256 (planned)	Isolated malware store	Collector → custodian
EV-08	Day −3 disconnected backup media and failed snapshots	Record condition; read-only use; copy for tests	ITO; FL	Day 0, to be recorded	Media serial and hash (planned)	Locked cabinet; originals never mounted read-write	Signed handoffs

Access restrictions. Access is need-to-know: IM, FL, SA and LP (read). The IM designates an evidence custodian. Evidence is stored apart from production and is accessed only from clean systems with local or break-glass accounts, never from compromised credentials. Analysis uses copies, never originals. Each access and transfer is logged with name, time and purpose, and two people sign every transfer.

3.5 Eradication, entry point and credentials

- **Persistence.** Search for and remove malicious services, scheduled tasks, startup entries, new accounts, mailbox rules and OAuth app consents. Rebuild FIN-PC07 and FS01 rather than clean them, once evidence is acquired.
- **Likely entry point (hypothesis, E01).** Treat the payroll attachment as the probable entry. Purge it from all mailboxes, block the sender and file type, and confirm with forensics that execution occurred. If analysis shows another entry route, I will revise the fix.

- **Credentials.** Treat the finance officer account, svc_backup, local administrators and any account that logged onto FIN-PC07 or FS01 as exposed. Rotate all of them, enforce MFA, and replace svc_backup with a least-privilege, vaulted account.

3.6 Restoration order, recovery targets and backup validation

Table 14. Restoration order and working targets (Assumption A8)

Order	Service	Working target	Conditions
0	Security baseline: rotated credentials, EDR on servers, clean build platform	Complete before any restore	Actions 9 and 10 closed
1	Exam-only LMS01 service with required content from FS01	Within 24 hours of 08:45 (recovery time target)	Validated backup; acceptance criteria met; BO approval
2	FS01 core shares (admissions, assessment records)	Within 48 hours	Integrity checks; privileged access reviewed
3	Rebuilt FIN-PC07 and finance files	Within 72 hours	Finance data validated; no live payroll risk
4	New backup repository with an offline or immutable copy	Started in parallel; complete before full return	No restored system returns without backup cover
5	Full LMS01 features and remaining services	Within 5 working days	Monitoring clean

Acceptable data loss. The working recovery point is the Day −3 17:00 backup, so up to about 64 hours of change can be lost (Friday 17:00 to Monday 08:45). Lost submissions and records will be rebuilt from learner copies, email, LMS logs and paper records where possible. The Business Owner must accept this loss in writing before restoration.

Backup selection and validation. (1) List candidate backups and the time each was taken. (2) Reject any set touched by svc_backup activity after E03 unless independently verified. (3) Check each timestamp against E01 (Day −1 16:40) and E03 (Day 0 01:35); the Day −3 backup predates both but could still hold earlier compromise, so it is scanned, not trusted. (4) Scan in an isolated sandbox with two engines. (5) Test-restore into a quarantined network. (6) Compare file counts and checksums with expected values. (7) Record results and decide.

Table 15. Recovery acceptance criteria

#	Criterion	Test and threshold	Approver
1	Backup provenance known	Source, time and custody documented; timestamp compared with E01 and E03	IM
2	Backup free of malware	Clean result from two engines and EDR in the sandbox; zero detections	SA
3	Backup readable and complete	Test restore completes with no read errors; expected file and database counts present (a repeat of the “unreadable snapshot” fault fails the backup)	ITO
4	Data integrity	Sample of at least 100 files opens correctly; checksum comparison matches where baselines exist; LMS test learner can log in, open materials and submit a test assessment	ITO; BO
5	Security baseline in place	Credentials rotated; MFA enforced; EDR active on every restored server; svc_backup replaced	SA

#	Criterion	Test and threshold	Approver
6	Persistence removed and entry point blocked	No indicators in fleet search; phishing email purged; rules and consents clean	FL; SA
7	Monitoring window passed	Staff-only pilot of at least 4 hours with no indicator alerts; enhanced monitoring for 14 days after return	SA
8	Business readiness	Learner notice ready; rollback tested; data loss accepted in writing	BO (final approval)

Task 4 Communication and escalation

4.1 Communication matrix

Corporate email is treated as unsafe until the Microsoft 365 account review is complete (E08, E02). The alternative channel is the phone cascade and SMS, plus an out-of-band messaging group for the CSIRT (Assumption A6).

Table 16. Communication matrix

Stakeholder group	Trigger	Message owner	Channel (alternative if email unsafe)	Approver	Update frequency
Learners (1,800; 100 exam candidates first)	Exam decision and service outage	CL	Website banner, portal login page notice, SMS if a clean contact export exists (A5). Alternative: public notice and phone line.	IM and ES; LP reviews data wording	First notice by 10:00; then every 4 hours or on change
Executive management	Critical declaration; decisions needed	IM	Phone call and out-of-band group	IM	Hourly for 4 hours, then every 4 hours
IT and security staff and CSIRT	Activation; new tasks	IM	Phone bridge and out-of-band group	IM	Every 30 minutes during the first 24 hours
Service providers (backup, Microsoft, forensic)	Support or evidence needed	ITO	Provider support line and portal; phone	ES for spend; IM for scope	At least every 2 hours while open
Legal and privacy advisers	Possible personal data exposure (E04, E06); attacker claim	IM	Phone, then secure file share	IM	At each new finding; at least 12:00 and 17:00
Staff (90)	Instructions: do not use FIN-PC07 or FS01; do not open suspicious mail; refer media to CL	CL	SMS and phone cascade; in-person briefing	IM	09:45, then each shift
Media and social enquiries	Inbound enquiry or public post	CL	Written holding statement	ES; LP reviews	As needed, one spokesperson only
Law enforcement or national CSIRT	Evidence of crime or extortion	LP	Official reporting channel	ES on LP advice	As the authority requests

4.2 Executive briefing (09:45 WAT, Day 0)

Status at 09:45 WAT, Monday. Confirmed: ransomware-type encryption on FIN-PC07 and FS01 (E06); learners cannot open materials or submit work (E07); the incident contact list is unavailable (E08). Both systems are isolated and the backup account is disabled. Uncertain: whether data was stolen (a 1.2 GB upload occurred, E04, content unknown); whether backups are clean (E03, E05); whether LMS01 itself is damaged. We have not identified the attacker or confirmed the malware family. Containment is under way and evidence is being preserved. Impact so far: finance and shared files are unavailable and learner access is disrupted. Decisions needed from you by 10:00: (1) approve postponing the 11:00 examination for 100 learners, because restoring from an unverified backup could reintroduce the attack; (2) approve engaging an external forensic provider and legal counsel; (3) confirm that no ransom contact or media comment occurs without your approval. Corporate email is treated as untrusted, so we are using phone and SMS. Next update: 10:45 WAT, then hourly.

4.3 Learner notice

Notice to learners. Northbridge Skills Institute is investigating a suspected cyber incident affecting some of our systems. As a precaution, learning materials and assessment submission are temporarily unavailable. Today's 11:00 online examination will not take place as scheduled. We will confirm a new date by 14:00 today, and no learner will be disadvantaged. What you should do: do not keep trying to log in; do not open unexpected emails or attachments claiming to be from the Institute; do not reply to anyone claiming to hold learner information; rely only on the Institute website and SMS for official updates. If you submitted work since Friday evening, keep a copy. We do not yet know whether any personal information is affected; if that changes, we will tell you directly. Questions: call +000 555 0100. Next update: 14:00 WAT.

4.4 Notification obligations and escalation rules

Assessing obligations. Legal or privacy advisers will first confirm the applicable jurisdiction and laws, because the brief does not state them (A1). They will decide whether there has been a personal data breach, using the confirmed facts from the log (not hypotheses), then identify the regulators, individuals, awarding bodies, insurers and partners that must be told, and the exact deadline and start point in the official text of the law. They record the decision and the reasoning. **No statutory deadline is asserted in this submission;** any deadline will be confirmed by counsel from the official legal text.

Operational notices versus formal breach notification. Operational notices (staff instructions, learner service updates, executive updates) tell people what is happening and what to do; they state only confirmed facts and make no claim about data. A formal breach notification is a legally required message to a regulator or affected individuals with prescribed content and timing; it is drafted and approved by the legal or privacy adviser and the Executive Sponsor and sent only after the assessment.

Table 17. Escalation rules

Trigger	Escalate to	Time limit	Action
Incident declared Critical	ES and BO	Immediately	Executive notification (ICDFA, 2026, slide 10); open continuity actions
Evidence suggests personal data was accessed or exfiltrated	LP and ES	Within 30 minutes	Start formal notification assessment; preserve evidence
Attacker deadline, ransom demand or publication threat	ES, LP, external provider	Within 15 minutes	No contact or payment without ES and LP approval; preserve the message
Media or social media enquiry	CL, then ES and LP	Within 15 minutes	Use the approved holding statement only

Trigger	Escalate to	Time limit	Action
Backup compromise confirmed or a restore fails	ES and BO	Within 30 minutes	Re-plan recovery time; reconsider exam date
Evidence of crime or extortion	LP and ES	Same day	Decide on law enforcement or national CSIRT report
A CSIRT role cannot be reached	Deputy for that role	Within 15 minutes	Use the deputy named on the contact list
IM unreachable or unfit to continue	ITO as deputy IM	Immediately	Deputy assumes command; ES informed

Task 5 Tabletop exercise and improvement plan

SIMULATION NOTICE. Everything in this task is a simulated walk-through performed individually by me, i take each role in turn. Results are simulated and are not real outcomes. The exercise clock starts at simulated 08:45 on Day 0 (Assumption A9).

5.1 Exercise design

Objectives. (1) Test activation, isolation authority and out-of-band coordination when the contact list is lost. (2) Test the exam and restoration decisions under management pressure. (3) Test whether communications stay accurate and consistent under rumour and an extortion claim.

Table 18. Participants and agenda

Role played	Focus in the exercise
Incident Manager (and facilitator)	Command decisions, log, escalation
Executive Sponsor	Approvals, risk acceptance, public statements
Security Analyst	Scope, indicators, identity
Forensics Lead	Evidence preservation and custody
IT Operations Lead	Isolation, backup validation, rebuild
Business Owner	Exam status, data loss, continuity
Legal and Privacy Adviser	Notification assessment, wording
Communications Lead	Learner, staff and media messages

Minute	Agenda item
0–5	Briefing, rules, and the starting situation (E01 to E08)
5–10	Initial response: activation, isolation, backups
10	**Inject 1** (required)
10–20	Discussion and decision
20	**Inject 2** (required)
20–28	Discussion and decision
28	**Inject 3** (my own)
28–35	Discussion and decision
35	**Inject 4** (required)
35–45	Discussion and decision
45	**Inject 5** (required)
45–55	Discussion and decision
55–60	Debrief and scoring against success criteria

Table 19. Injects

Minute	Inject
10	Management asks you to reopen the learning portal before the 11:00 examination, even if the most recent backup is unverified.

Minute	Inject
20	An attacker claims to hold all 1,800 learner records and threatens publication in 12 hours. A screenshot is provided; its authenticity is unknown.
28 (own)	EDR flags the same suspicious process and a file-creation pattern on a registry office workstation (REG-PC03), which holds admission documents. This tests scope expansion.
35	A test restoration of the latest network backup fails with an unreadable snapshot error.
45	A social media post claims the examination is cancelled. A journalist asks whether learner information has been exposed.

Success criteria (measurable).

- SC1: All six core roles reached by phone and confirmed within 15 minutes of the start.
- SC2: Isolation of FIN-PC07 and FS01 and disabling of svc_backup decided with documented authority within 15 minutes.
- SC3: Volatile evidence from FIN-PC07 planned for capture before any rebuild decision, with a register entry and custody record for each item.
- SC4: Exam decision and first learner notice approved within 45 minutes of the start.
- SC5: No restoration to production from any backup that lacks documented validation (target: zero breaches).

5.2 Simulated walk-through by role

Table 20a. Inject 1 (minute 10): reopen the portal

Role	Simulated response
Incident Manager	Decline reopening on an unverified backup; explain risk and options; ask ES to decide on postponement.
Executive Sponsor	Asks for the risk in plain terms; accepts postponement if no safe path exists.
Security Analyst	Warns that persistence may remain, so learners could be exposed to re-encryption or credential capture.
Forensics Lead	Warns that restoring over affected systems overwrites evidence; images come first.
IT Operations Lead	States the earliest clean exam-only build is about 24 hours; Day −3 backup not yet validated.
Business Owner	Prefers to run the exam but accepts a later date over an unsafe one; asks for fallback options.
Legal and Privacy	Notes that unsafe reopening could worsen any personal data obligations.
Communications Lead	Drafts a holding statement and a postponement notice.

Table 20b. Inject 2 (minute 20): attacker claim and screenshot

Role	Simulated response
Incident Manager	Treats the claim as unverified but credible; logs it; no contact or payment; escalates to ES and LP.
Executive Sponsor	Confirms no ransom contact without ES and LP approval; asks about law enforcement.
Security Analyst	Compares screenshot fields with LMS and admissions data layouts; matches against E04; checks threat intelligence.

Role	Simulated response
Forensics Lead	Stores the screenshot as evidence with a hash recorded on receipt; prioritises analysis of E04 content.
IT Operations Lead	Identifies which systems hold the 1,800 learner records; checks for bulk reads.
Business Owner	Wants to know what learners will be told; supports a precautionary notice if the claim is verified.
Legal and Privacy	Opens the formal notification assessment; treats the 12-hour threat as an operational trigger, not a legal deadline.
Communications Lead	Prepares a reactive statement and FAQ; no statement on data until LP approves.

Table 20c. Inject 3 (minute 28, own): second endpoint REG-PC03

Role	Simulated response
Incident Manager	Declares scope expansion; orders isolation of REG-PC03; widens the hunt to all endpoints; updates ES.
Executive Sponsor	Approves precautionary restrictions even if staff work is disrupted.
Security Analyst	Pulls process, parent and network telemetry; searches the fleet for the same indicators.
Forensics Lead	Prioritises memory capture of REG-PC03 before any reimage.
IT Operations Lead	Isolates the host; blocks SMB and RDP between workstations and servers.
Business Owner	Accepts registry office disruption; identifies critical admissions work needing a manual workaround.
Legal and Privacy	Notes admission documents on this host widen the personal data scope.
Communications Lead	Informs staff through the phone cascade; no external statement.

Table 20d. Inject 4 (minute 35): unreadable backup snapshot

Role	Simulated response
Incident Manager	Declares the network backup unusable; switches to validating the Day −3 disconnected backup; resets recovery times.
Executive Sponsor	Approves the external forensic provider and extra support; accepts exam postponement.
Security Analyst	Checks whether the snapshot was corrupted or tampered with; reviews BAK01 audit logs (E03, E05).
Forensics Lead	Preserves the failed snapshot and BAK01 logs as evidence.
IT Operations Lead	Fetches the Friday media; builds the isolated sandbox; starts validation scans.
Business Owner	Confirms the exam cannot proceed; asks for the earliest new date; starts assessing data loss since Friday.
Legal and Privacy	Notes possible backup tampering; considers informing the insurer and law enforcement.
Communications Lead	Updates staff and learners: exam postponed, recovery under way.

Table 20e. Inject 5 (minute 45): rumour and journalist

Role	Simulated response
Incident Manager	Orders verification; confirms postponement is already decided; insists on a single spokesperson.
Executive Sponsor	Approves the statement and acts as spokesperson; no speculation.
Security Analyst	Checks whether the post links to the attacker's claim; monitors for leak posts.
Forensics Lead	Preserves the post and URLs as evidence.
IT Operations Lead	Prepares the website banner and SMS channels.
Business Owner	Confirms accurate exam status and the process for the new date.
Legal and Privacy	Reviews wording: "investigating", not "no data exposed"; no confirmation of compromise.
Communications Lead	Publishes the verified status; sends the holding statement to the journalist.

5.3 Decision log (simulated)

Table 21. Decision log

Inject	Decision	Decision owner	Rationale	Communication	Effect on plan
1 (min 10)	Do not reopen the portal or restore from an unverified backup; recommend postponing the exam.	ES, on IM advice; BO consulted	Backup safety unproven (E05); risk of reinfection and evidence loss.	Holding statement drafted; staff told	Exam gate brought forward in the plan; exam-only build prioritised
2 (min 20)	Treat the claim as unverified; no contact or payment; start notification assessment.	ES with LP	Authenticity unknown; E04 makes theft plausible; payment is discouraged (CISA & partners, 2023).	Reactive statement held; LP briefed	Data-scope work (Q1) moved to top priority
3 (min 28)	Isolate REG-PC03; widen the fleet hunt; restrict SMB and RDP between workstations and servers.	IM	Same indicators on a second host suggest spread.	Staff phone cascade	Scope grows; admissions data added to the exposure review
4 (min 35)	Reject the network backup; validate the Day −3 disconnected backup; engage the external provider.	IM; ES approves spend	Unreadable snapshot; svc_backup concerns (E03).	Staff and learner updates; ES briefed	Recovery time target moves to exam-only service within 24 hours
5 (min 45)	Confirm exam postponement publicly; reply to the journalist with a holding statement only.	ES; CL drafts; LP reviews	A rumour had overtaken the plan; claims about data cannot yet be made.	Website, portal notice, SMS; written reply to journalist	Notice timing in the playbook changed (improvement 2)

5.4 Evaluation against success criteria (simulated)

Table 22. Results

Criterion	Simulated result	Met?
SC1 Six core roles within 15 minutes	Five of six reached within 15 minutes; the legal adviser's number was held only on FS01.	Partly
SC2 Isolation decision within 15 minutes	Isolation and svc_backup disabling decided at minute 8 with IM authority recorded.	Met
SC3 Evidence before rebuild	FIN-PC07 evidence planned first; no memory capture possible for FS01 because it has no EDR agent.	Partly
SC4 Exam decision and learner notice within 45 minutes	Notice approved at minute 52; rumour appeared at minute 45.	Not met
SC5 No unvalidated restoration	Zero unvalidated restores; inject 1 refused and inject 4 triggered the fallback.	Met

5.5 Improvement plan and review

Table 23. Improvements

#	Improvement	Priority	Owner	Target completion	Measurable evidence of completion
1	Keep an out-of-band incident contact list, including deputies and legal or privacy advisers.	Critical	IM	Within 3 working days	Test call reaches 100% of CSIRT members and deputies within 15 minutes
2	Make exam postponement the pre-approved default when backup safety is unproven; pre-approve learner and staff templates; first notice by 09:15.	High	BO and CL	Within 5 working days	Templates approved by ES and LP; notice issued within 30 minutes in the next drill
3	Add an immutable or offline backup and run a monthly restore test of FS01 and LMS01.	Critical	ITO	Within 30 days	Documented restore test with measured time and a pass result
4	Extend EDR to all servers (FS01, LMS01, BAK01).	Critical	SA	Within 14 days	Coverage report shows 100% of servers; test alert received
5	Sign a forensic and incident response retainer with out-of-hours contact.	High	ES	Within 14 days	Signed engagement; contact call tested
6	Redesign svc_backup privileges and alerting for off-schedule logons.	High	ITO	Within 21 days	Access review signed; test logon alert fires within 15 minutes

Review and closure. The post-incident review will be held within 14 days of incident closure, in line with the teaching deck (ICDFA, 2026, slide 12), and the exercise improvements will be reviewed at the same meeting. The review is blame-free. The Executive Sponsor closes each action once the Incident Manager has verified the evidence of completion, consistent with the RACI (Table 10, row 10).

Task 6 Case study analysis and critical reflection

The ICDFA case (slide 16) describes a mid-size healthcare organisation (2,500 employees) hit by a Ryuk-variant ransomware attack delivered by a phishing attachment. It is illustrative, so my conclusions rest only on what the slide states.

Strengths. First, the pre-established IR team and playbooks allowed immediate activation once EDR alerts fired on Day 4. Second, offline backups were verified intact before restoration, which avoided a ransom payment and matches CISA guidance to keep offline, encrypted, regularly tested backups (CISA & partners, 2023). Third, network segmentation limited spread, and regulatory notifications and ISAC sharing were completed.

Limitations and unresolved issues. First, the attacker moved laterally for 72 hours before encryption triggered, so detection was late, and the slide does not explain why earlier indicators were missed. Second, the statement that no patient data exfiltration was confirmed has no stated basis, and backup testing exposed restoration gaps, so recovery assurance was weaker than the outcome suggests.

Transfer to Northbridge. I would transfer (1) tested offline backups with routine restoration drills, because Northbridge's only trusted recovery point is a Friday disconnected copy and no restore has been tested in 90 days; and (2) network segmentation, separating BAK01 and service accounts from file and learning servers, because E03 shows one account reaching both FS01 and BAK01.

72 hours versus seven days. Restoring critical systems within 72 hours returns priority services, whereas full restoration also covers lower-priority systems, integrity validation, hardening and phased return under monitoring. The first is a continuity target; the second marks recovery completion. Treating them as equal would hide residual risk.

Evidence before claiming no data was stolen. I would need complete egress, proxy, firewall, EDR and cloud audit logs for the whole dwell period; analysis showing no staging or archiving of patient records; confirmation of which systems the attacker touched; and no extortion or leak-site claims. Logging gaps would limit the claim to "no evidence of exfiltration".

Revised decision. After the tabletop I would revise the 09:45 exam go or no-go gate. The social media rumour at minute 45 showed that a learner notice must be ready sooner, so I would make postponement the pre-approved default and issue the first notice by 09:15.

Appendix A Assumptions register

ID	Assumption
A1	The jurisdiction is not stated in the brief. No statutory deadline is asserted. Counsel will confirm from the official legal text.
A2	Response time for High incidents (1 hour) and objective timings (30 minutes) are institute policy values chosen by the author.
A3	No forensic retainer exists at 08:45. An external provider is engaged ad hoc; the Security Analyst acts as forensics lead for evidence capture until then.
A4	FIN-PC07 and FS01 are still powered on at 08:45. FS01 has no EDR agent because server coverage is incomplete.
A5	Learner mobile numbers can be exported from a source other than FS01. If not, the website and portal notice are used.
A6	Staff mobile phones and an out-of-band messaging group are acceptable for incident coordination.
A7	The Day −3 17:00 disconnected backup is physically available within one hour and was not connected to the network afterwards.
A8	No business impact analysis exists yet, so recovery times (24, 48, 72 hours, 5 working days) and the data-loss tolerance are working targets for this incident.
A9	The tabletop clock starts at simulated 08:45 on Day 0.
A10	All roles are described by function; named individuals are fictional or not given.

References

CISA, FBI, NSA, & MS-ISAC. (2023). #StopRansomware guide. Cybersecurity and Infrastructure Security Agency. https://www.cisa.gov/resources-tools/resources/stopransomware-guide

ICDFA. (2026, October 4). Incident response planning [Teaching deck, slides 1–18]. GRC105, Week 20. International Cybersecurity and Digital Forensics Academy.

National Institute of Standards and Technology. (2025). Incident response recommendations and considerations for cybersecurity risk management (NIST Special Publication 800-61 Rev. 3). https://csrc.nist.gov/pubs/sp/800/61/r3/final

National Institute of Standards and Technology. (2025). Incident response: Framework and life cycle overview [Project page]. https://csrc.nist.gov/projects/incident-response

Source-to-decision map

Source	Decision or section it supports
ICDFA (2026), slides 4 and 10	Incident type and severity levels; executive notification for Critical (Task 1)
ICDFA (2026), slides 7–8 and 14–15	Preparation checklist, plan components, CSIRT roles and RACI structure (Task 2)
ICDFA (2026), slides 11–13	Containment and eradication sequence; documentation; blame-free review within two weeks (Tasks 3 and 5)
ICDFA (2026), slide 16	Case study analysis and transferred changes (Task 6)
ICDFA (2026), slide 18	Link to business continuity: recovery time and data-loss targets (Tasks 2 and 3)
NIST (2025)	CSF 2.0 alignment of incident response and preparation functions; continuous improvement (Framework section)
CISA & partners (2023)	Isolation with memory and image capture; offline tested backups; ransom payment discouraged (Tasks 2, 3, 5 and 6)

Acknowledgement of AI assistance

This report was drafted with assistance from an AI model (Claude, Anthropic), using the course brief, the teaching deck and the approved sources above. I reviewed, edited and take responsibility for the analysis and decisions, and I am prepared to explain them if the instructor asks.